

# Post-Feature Hardening Plan

After features ship — security, perf, deploy, compliance

Academic Platform · 2026-06-07

# Post-Feature Hardening Plan

**When:** AFTER all 8 build phases shipped + features stable. **Goal:** Take working app → production-grade, secure, observable, deployable. **Owner:** Solo dev. **Scope:** Architecture, security, performance, deployment, compliance.

## Phase H1 — Security & Auth Hardening (1 day)

Production-blocking items. Do first.

| #    | Task                                                                                                                 | Why                                      | Effort        |
|------|----------------------------------------------------------------------------------------------------------------------|------------------------------------------|---------------|
| H1.1 | Rate limit <code>/api/signup</code> , <code>/api/auth/*</code> , <code>/api/ai/*</code> , <code>/api/judge0/*</code> | Bot signup, AI cost runaway, brute-force | 2h            |
| H1.2 | CSRF + cookie audit — confirm <code>Auth.js secure: true</code> , <code>sameSite: lax</code> in prod                 | Session hijack                           | 30m           |
| H1.3 | Strong <code>AUTH_SECRET</code> per env (dev/staging/prod)                                                           | Token forgery                            | 15m           |
| H1.4 | JWT TTL drop to 1h + silent refresh                                                                                  | Force-revoke after admin demote/reject   | 2h            |
| H1.5 | Password reset flow — token + email                                                                                  | Currently no recovery path               | 4h            |
| H1.6 | Audit log review UI at <code>/admin/audit</code>                                                                     | Compliance + incident review             | 2h            |
| H1.7 | Cross-board access test — student A logs in, requests subject from board B → must 404                                | Multi-tenant leak                        | 1h test + fix |
| H1.8 | 2FA TOTP for super-admin role                                                                                        | Admin account compromise                 | 3h            |
| H1.9 | CSP + HSTS + X-Frame-Options via <code>next.config.ts</code> headers                                                 | XSS, clickjacking                        | 1h            |

**Gate:** Penetration smoke test — try common OWASP 10 vectors, all blocked.

## Phase H2 — Observability (half day)

| #    | Task                                                                     | Tool                             | Effort |
|------|--------------------------------------------------------------------------|----------------------------------|--------|
| H2.1 | Sentry — JS + server errors, source maps, release tagging                | @sentry/nextjs free 5k events/mo | 2h     |
| H2.2 | Structured logs — pino JSON, ship to file → Coolify log volume           | grep-able prod logs              | 1h     |
| H2.3 | Health endpoint extended — DB ping, R2 ping, Groq ping                   | Detect upstream failure          | 1h     |
| H2.4 | Uptime monitor — Coolify built-in OR UptimeRobot free                    | 5-min interval, email alert      | 30m    |
| H2.5 | AI cost meter — log Groq req count + tokens per cache key into audit_log | Spot expensive prompts           | 2h     |
| H2.6 | Slow query log — Postgres<br>log_min_duration_statement = 500ms          | Catch index gaps                 | 15m    |

**Gate:** Trigger a 500, see it in Sentry within 1 min. Trigger DB down, see uptime alert.

## Phase H3 — Backups & DR (half day)

| #    | Task                                                                          | Effort       |
|------|-------------------------------------------------------------------------------|--------------|
| H3.1 | pg_dump nightly cron → R2 bucket, 14-day retention                            | 2h           |
| H3.2 | R2 lifecycle rule — orphan PDFs auto-delete after 7d if no content_assets row | 2h           |
| H3.3 | Restore drill — wipe dev DB, restore from latest dump, verify app works       | 1h           |
| H3.4 | Document recovery runbook in docs/RUNBOOK.md                                  | 1h           |
| H3.5 | Migration safety — pg_dump immediately before every drizzle migrate in prod   | doc + script |

**RTO target:** 1h (manual restore acceptable solo). **RPO target:** 24h.

## Phase H4 — Performance (1 day)

| #    | Task                                                                                                                             | Effort      |
|------|----------------------------------------------------------------------------------------------------------------------------------|-------------|
| H4.1 | Font preload — Instrument Serif + Geist in <code>&lt;head&gt;</code>                                                             | 30m         |
| H4.2 | <code>next/image</code> everywhere, R2 loader, AVIF/WebP                                                                         | 2h          |
| H4.3 | Lazy load <code>react-pdf</code> , Monaco editor — only on topic/coding pages                                                    | 2h          |
| H4.4 | Postgres indexes review — run <code>EXPLAIN ANALYZE</code> on hot queries (subjects list, approvals queue, analytics drill-down) | 2h          |
| H4.5 | Connection pool — Drizzle <code>max: 10</code> , <code>idleTimeoutMillis: 30000</code>                                           | 15m         |
| H4.6 | Static page caching — <code>revalidate</code> on public marketing pages                                                          | 30m         |
| H4.7 | Lighthouse audit — target 90+ on Performance, Accessibility, Best Practices                                                      | 2h fix loop |
| H4.8 | Bundle analyzer — strip unused deps, code-split admin away from student                                                          | 2h          |

**Gate:** First-load JS < 200KB on `/dashboard`. LCP < 2.5s on 4G.

## Phase H5 — Email & Notifications (half day)

| #    | Task                                                                                 | Tool                    | Effort |
|------|--------------------------------------------------------------------------------------|-------------------------|--------|
| H5.1 | Resend account + domain SPF/DKIM/DMARC records                                       | Resend free 100/day     | 1h     |
| H5.2 | Email templates — welcome, approved, rejected, password reset                        | React Email             | 2h     |
| H5.3 | Trigger emails from server actions (signup, approve, reject)                         | Background job optional | 1h     |
| H5.4 | In-app notification center — DB table <code>notifications</code> , header bell badge | 3h                      |        |
| H5.5 | Daily digest (optional) — admin gets pending-approvals count by email                | 1h                      |        |

**Gate:** Sign up → welcome email lands in Gmail inbox, not spam.

## Phase H6 — Compliance & Legal (1 day)

---

India-specific + general PII handling.

| #    | Task                                                                                                     | Why                                             | Effort |
|------|----------------------------------------------------------------------------------------------------------|-------------------------------------------------|--------|
| H6.1 | DPDP Act consent banner — store consent in <code>users.consent_at</code>                                 | India Digital Personal Data Protection Act 2023 | 3h     |
| H6.2 | Privacy policy page + Terms page                                                                         | Required for paid platforms                     | 2h     |
| H6.3 | Cookie consent (if GDPR/EU visitors expected)                                                            | EU GDPR                                         | 1h     |
| H6.4 | Data export endpoint — student can download their data as JSON                                           | DPDP right to access                            | 2h     |
| H6.5 | Account deletion — soft delete + 30-day purge cron                                                       | DPDP right to erasure                           | 3h     |
| H6.6 | PII audit — confirm phone/email encrypted at rest? Postgres TDE not needed if hosting trusted; document. | doc                                             | 1h     |
| H6.7 | Audit log retention — keep 2 years for compliance                                                        | cron purge older                                | 30m    |

**Gate:** Privacy policy live, consent banner shows on first visit, data export downloads.

---

## Phase H7 — CI/CD & Deploy (1 day)

| #     | Task                                                                                             | Effort |
|-------|--------------------------------------------------------------------------------------------------|--------|
| H7.1  | GitHub Actions: install → typecheck → lint → drizzle generate diff check → unit tests            | 2h     |
| H7.2  | Block merge to <code>main</code> if CI red                                                       | 15m    |
| H7.3  | Hetzner CPX21 provision + Coolify install                                                        | 1h     |
| H7.4  | Domain DNS → Cloudflare → Coolify                                                                | 30m    |
| H7.5  | Let's Encrypt SSL via Coolify                                                                    | auto   |
| H7.6  | Production env vars in Coolify (DB URL, AUTH_SECRET, R2 creds, Groq key, Resend key, Judge0 key) | 30m    |
| H7.7  | First migration to prod DB                                                                       | 30m    |
| H7.8  | Self-host Judge0 alongside app on VPS                                                            | 2h     |
| H7.9  | Coolify auto-deploy on push to <code>main</code>                                                 | 30m    |
| H7.10 | Smoke test prod — full signup → approval → topic → test → interview flow                         | 1h     |

**Gate:** Push to main → deploy lands → smoke flow green within 5 min.

## Phase H8 — Polish & UX (1 day)

Defer-friendly.

| #    | Task                                                                                     | Effort |
|------|------------------------------------------------------------------------------------------|--------|
| H8.1 | <code>not-found.tsx</code> , <code>error.tsx</code> , <code>loading.tsx</code> per route | 2h     |
| H8.2 | Dark mode toggle — <code>next-themes</code> + theme switcher in header                   | 2h     |
| H8.3 | Onboarding tour for first-login students                                                 | 3h     |
| H8.4 | Empty states audit — every list has decent empty design                                  | 1h     |
| H8.5 | Skeleton loaders on async dashboards                                                     | 2h     |
| H8.6 | Mobile responsive QA — every page on iPhone SE viewport                                  | 2h     |
| H8.7 | Accessibility audit — axe-core run, fix WCAG AA failures                                 | 3h     |
| H8.8 | SEO: <code>robots.ts</code> , <code>sitemap.ts</code> , OG images, meta tags             | 2h     |

**Gate:** Lighthouse Accessibility = 100. No console errors on mobile Safari.

## Phase H9 — Indian Market Essentials (1 day)

When ready to scale users beyond initial cohort.

| #    | Task                                                           | Effort |
|------|----------------------------------------------------------------|--------|
| H9.1 | Razorpay stub — subscription table + checkout webhook          | 4h     |
| H9.2 | Hindi i18n via <code>next-intl</code> — auth + dashboard first | 4h     |
| H9.3 | Phone-OTP signup (instead of email) — Twilio India / MSG91     | 4h     |
| H9.4 | Low-bandwidth mode — text-only fallback, PDF compression       | 2h     |

## Phase H10 — Operational (ongoing)

Cron + maintenance.

| #     | Task                                                          | Schedule          |
|-------|---------------------------------------------------------------|-------------------|
| H10.1 | DB backup → R2                                                | nightly 02:00 IST |
| H10.2 | Stale <code>in_progress</code> test attempts → mark abandoned | hourly            |
| H10.3 | AI cache hit-rate metrics → admin dashboard tile              | daily             |
| H10.4 | Orphan R2 object cleanup                                      | weekly            |
| H10.5 | Old <code>audit_log</code> > 2y → archive                     | monthly           |
| H10.6 | Dependency security audit — <code>pnpm audit</code>           | weekly via CI     |
| H10.7 | Backup restore drill                                          | quarterly         |

## Architecture-level open items

These are decisions / design questions to resolve during hardening, not code.

1. **AI cache eviction policy** — currently `generated_content` grows unbounded. Decision: keep forever (storage cheap, hits free). Add manual purge button only.
2. **progress table query cost** — at 10K students × 1K topics, JOIN for subject %-complete may slow. Add materialized view `student_subject_progress` if `EXPLAIN` shows > 200ms.
3. **Multi-tenant test discipline** — add a CI integration test: log in as CBSE student, fetch ICSE topic by ID → must 404. Run on every PR.
4. **Judge0 self-host vs RapidAPI** — RapidAPI fine until ~500 submissions/day. Switch to self-host when that's regular.
5. **JWT vs DB sessions** — JWT cheaper but no force-revoke. Decision: JWT TTL 1h + refresh, OR switch to Auth.js DB sessions in `users.sessions`. Pick based on whether mid-session demote matters.
6. **Email deliverability** — Resend works; ensure SPF/DKIM/DMARC on domain or approval emails will spam-folder.
7. **TimeZone display** — backend stores UTC. Frontend renders user's local via `Intl.DateTimeFormat`. India = IST = UTC+5:30. Schools in different states unaffected.
8. **Sandbox language whitelist** — restrict Judge0 to Python, Java, C++, JS for v1. Each added language = added review burden.

## What we are NOT building (locked decisions)

- **✗** Microservices / NestJS split — modular monolith decided in Phase 0 research



- ❌ Kubernetes — single Hetzner VPS enough
- ❌ Redis — Postgres handles cache + JWT covers sessions
- ❌ Qdrant / vector DB — topic content small, RAG not needed
- ❌ Apache Kafka / event bus — not at this scale
- ❌ GraphQL — REST + server actions sufficient
- ❌ Read replicas — low traffic, premature
- ❌ Service mesh — over-engineering
- ❌ Video mock interview — voice + text is the v1 cut

## Total effort estimate

| Phase             | Days                                  |
|-------------------|---------------------------------------|
| H1 Security       | 1                                     |
| H2 Observability  | 0.5                                   |
| H3 Backups & DR   | 0.5                                   |
| H4 Performance    | 1                                     |
| H5 Email          | 0.5                                   |
| H6 Compliance     | 1                                     |
| H7 CI/CD & Deploy | 1                                     |
| H8 Polish & UX    | 1                                     |
| H9 Indian-market  | 1 (optional, defer)                   |
| H10 Operational   | ongoing                               |
| <b>Total</b>      | <b>~7-8 days</b> for H1–H8, +1 for H9 |

After feature phases 0-7 (~30 days) finish, this hardening track = roughly 7-10 days to production-ready.

## Order of execution after features done

---

H7 (deploy) → H1 (security) → H2 (observability) → H3 (backups)  
→ H4 (performance) → H5 (email) → H6 (compliance) → H8 (polish)  
→ H9 (Indian market, when needed)  
→ H10 ongoing

Reason: deploy first to find prod-only issues, then harden against them.

---

## Status

---

- **Now:** Building Phases 1-7 features (auth, curriculum, content, mock test, interview, coding, analytics).
- **After:** This document.
- **Updated:** 2026-06-07